

高安全属性价值设备威胁态势量化评估方法

摘要

传统的网络安全态势量化评估方法主要面向宏观网络安全态势，未针对安全价值较高的网络设备。本文给出了高安全属性价值设备的定义，设计了针对设备的威胁态势量化评估框架和评估指标，并根据评估框架和指标提出了高安全属性价值设备威胁态势量化评估方法。对具体网络中实际设备的评估结果表明，该方法能够准确、有效地量化评估高安全属性价值设备的威胁态势。

关键词：态势感知；安全威胁；量化评估；高安全属性价值设备

1 引言

网络信息智能化防御中，网络安全态势感知是前提和基础。网络安全态势感知能够对引起网络安全态势变化的要素进行获取、理解、评估、可视化及预测未来发展趋势。其中，网络安全态势评估能够从宏观上动态反映网络的安全状态，当前网络层面的态势评估方法相对成熟，虽有差异，但从研究思路及对态势感知的诠释上接受并延续了 JDL 数据融合思想和 Endsley 态势感知层次模型。

网络安全态势评估的常规过程是：利用网络探针或网络传感器收集全网态势数据，利用数据融合的方式处理态势要素，使用数学模型、知识推理、模式识别等基于知识的方法对网络安全态势进行量化评估。随着网络攻防博弈的不断演进，大数据分析和机器学习等基于数据的方法在感知、察觉网络状态、检测网络攻击、预测网络风险等方面不断有所突破，逐渐形成了针对网络安全的态势感知体系，并通过基于知识、基于数据及知识和数据融合的方法，建立了对网络安全要素认知、理解、评估的模式，在评估网络宏观安全态势方面给出了有效的解决途径。

但在微观具体化、针对性方面还存在不足。现有方法通常只能反映单位时间内网络宏观安全状态及变化趋势，无法在微观层面有针对性地呈现网络中高安全属性价值设备面临的威胁、脆弱性的危害程度、安全事件发生的可能性以及拒绝服务导致的性能劣化程度等设备威胁态势。

例如，已有研究分别利用马尔可夫博弈模型和隐马尔可夫模型对网络安全状态建模，通过博弈论方法确定网络的状态变化。这类方法基于网络状态遵循马尔可夫随机过程的假设，在多步攻击的实际场景中存在局限。当网络受到多步攻击时，网络被攻破的状态不仅与攻击持续作用相关，而且与网络边界或核心位置设备的状态紧密相关；甚至在特定多步攻击场景中，高安全属性价值设备的状态对全网的安全状态具有决定性影响。某种意义上，攻破该类设备等价于攻破网络。

此外, 还有研究从多步攻击角度描述网络状态, 利用节点状态确定攻击场景, 用以评估网络安全态势, 但仅考虑节点状态与漏洞、安全事件及前置状态之间的逻辑关系, 无法客观反映节点状态与网络环境、设备属性相关的实际情况。也有方法利用网络环境属性判定安全事件发生的可能性, 提高威胁感知量化评估准确性, 但未考虑节点性能劣化对威胁量化评估的影响, 也无法确定节点所处的安全状态。针对路由器设备的威胁态势评估方法能够直观反映其安全威胁风险, 但仅针对路由器的具体特征, 没有抽象出高安全价值设备威胁量化评估的普适特征。

针对上述问题, 本文首先给出高安全属性价值设备定义, 在此基础上提出面向设备的威胁态势量化评估框架和评估指标, 并据此提出高安全属性价值设备威胁态势量化评估方法。该方法以设备的性能、配置和脆弱性为基础, 验证威胁警报、评估威胁警报的有效性, 基于有效警报构建设备状态评估算法, 评估设备所处安全状态, 并利用评估指标量化计算设备威胁态势。

2 相关定义

本节给出本文工作所用的相关定义。

定义 1 (设备) 网络环境中的物理实体, 单个设备可表示为

$$e\text{-device} = (id_e, name_e, type_e, attrivalue_e, config_e),$$

其中, id_e 为设备标识, $name_e$ 为设备名称, $type_e$ 为设备类型, 包括安全设备、保密设备、网络设备、服务设备和终端设备等; $attrivalue_e$ 为设备安全属性价值; $config_e$ 为设备配置信息。

定义 2 (安全属性价值) 网络环境中设备具有保密性、完整性和可用性三种安全属性。设备在网络中的价值由其安全属性达成或未达成时造成的影响程度来衡量。设备安全属性价值记为

$$attrivalue_e = f(conf_e, int_e, avail_e),$$

其中, $conf_e$ 、 int_e 、 $avail_e$ 分别表示设备的保密性、完整性和可用性属性, 每个属性分为 5 级, 用 1,2,3,4,5 表示; $w_i (i = 1, 2, 3)$ 表示三种安全属性的权重。原文给出了基于三类属性和权重的组合计算式。

定义 3 (高安全属性价值设备) 根据 GB/T 20984-2007 对资产价值等级及标识的赋值, 当设备安全属性价值满足

$$attrivalue_e \geq \varepsilon, \quad 4 \leq \varepsilon \leq 5$$

时, 设备被定义为高安全属性价值设备。

定义 4 (设备配置) 用于表征设备配置及服务的属性信息, 可表示为

$$config_e = (ip_e, name_e, port_e, service_e, confdescription_e),$$

其中, ip_e 为设备 IP 地址池, $port_e$ 为设备配置的端口组, $service_e$ 为设备提供的服务,

$confdescription_e$ 为设备固件、软件类型、版本、硬件配置等其他信息。

定义 5（设备警报） 由设备发出的针对可疑安全事件或异常事件的通知。单个警报信息可表示为

$$alert_e = (id_a, name_a, time_a, souIP_a, desIP_a, \\ souPort_a, desPort_a, alertdescription_a, id_e, name_e).$$

其中, id_a 表示警报标识, $name_a$ 表示警报名称, $time_a$ 表示警报产生时间, $souIP_a$ 与 $desIP_a$ 分别表示源 IP 地址和目标 IP 地址, $souPort_a$ 与 $desPort_a$ 分别表示源端口和目标端口。

定义 6（设备脆弱性） 由设备软硬件中自身存在、可被威胁利用的异常或漏洞构成, 包括异常标识、异常类型、严重程度以及漏洞的 CVE 编号、名称、描述和 CVSS 评分等信息。设备脆弱性严重程度记为 $severity$ 。

定义 7（设备性能） 设备提供服务的基本能力。设备性能信息可表示为

$$perinfo_e = (id_p, cp, temp_p, bp, mp, ses_p, loss_p, id_e, name_e),$$

其中, cp 表示 CPU 利用率, $temp_p$ 表示设备内部温度, bp 表示带宽利用率, mp 表示内存利用率, ses_p 表示会话连接数, $loss_p$ 表示丢包率。原文进一步将设备性能值扩展为这 6 个参数构成的函数。

定义 $\pi(0 \leq \pi \leq 1)$ 为设备性能劣化对设备态势的影响程度; $\Delta per_e(i)$ 为第 i 个采样点与第 $i-1$ 个采样点间的性能变化量; $\sum \Delta per_e(i)$ 为性能变化累积量。当设备性能劣化时, $\sum \Delta per_e(i) < 0$ 。

定义 8（设备状态） 用于表征威胁作用到设备后设备所处的安全状态, 记为

$$E_{status} = \{X_1, X_2, \dots, X_i, \dots, X_j, \dots, X_n\},$$

其中 $status_probability = p_{threat}(X_j)$ 为设备处于状态 X_j 的可能性, $status_loss$ 为威胁有效作用到设备上造成的损失。

一般而言, 设备在遭受实质性攻击前, 会被通过 IP 扫描、端口扫描、存活性扫描、漏洞扫描等手段进行侦测, 此时设备处于被扫描状态; 扫描确定设备为攻击对象后, 攻击者会尝试通过提权等方式访问设备资源, 此时设备处于被攻击状态; 若攻击者能够有效利用设备存在的脆弱性, 则设备将处于被攻破状态; 若无法有效利用脆弱性, 也可能进一步发起拒绝服务攻击, 最终使设备瘫痪。

3 设备威胁态势量化评估框架与评估指标

设备的威胁态势不仅与设备受到的威胁有关, 还与设备安全属性价值、设备脆弱性、设备配置、设备警报、设备性能及设备状态等因素有关。基于这些因素, 本文提出设备威胁态势评估框架。根据该框架, 具体评估流程如下:

1. 获取设备态势相关的属性信息

$$devattrinfo = (\{alert_e\}, config_e, vulnerabilities_e, perinfo_e),$$

其中 $\{alert_e\}$ 为警报集合。

2. 建立评估指标体系

$$indexsys = (attrvalue_e, \Delta t, \pi, \sum \Delta per_e(i), severity, status_loss, status_probability).$$

3. 以设备性能、配置、脆弱性为基础，验证警报并评估威胁警报的有效性。

4. 基于有效警报，构建设备受到威胁后的状态评估算法，评估设备所处安全状态。

5. 综合利用评估指标，量化计算设备威胁态势 ETSA (e-device threat situational awareness)。

表 1 给出了原文的评估指标结构。

表 1: 评估指标

$attrvalue_e$	$\Delta t / \pi$	Δper_e	$severity$	$status_loss$	$status_probability$
$conf_e$	t_i	$per_e(i)$	$severity_{abn}$	$attrvalue_e$	$p_{threat}(X_j)$
int_e	t_{i-1}	$per_e(i-1)$	$cvsb_b$	$severity$	—
$avail_e$	$\Delta t =$ $t_i - t_{i-1}$	$\Delta per_e =$ $per_e(i) -$ $per_e(i-1)$	—	—	—
w_i	π	$\sum \Delta per_e(i)$	—	—	—

4 设备威胁态势量化评估方法

根据上一节提出的评估框架，本文设计了高安全属性价值设备威胁态势量化评估方法。该方法在获取设备威胁态势相关属性信息和建立评估指标体系后，需要先以设备性能、配置和脆弱性为基础，验证警报、评估威胁警报的有效性；进而基于有效警报构建设备受到威胁后的状态评估算法，评估设备所处安全状态；最后综合利用评估指标量化计算设备威胁态势。

4.1 威胁警报有效性评估算法

威胁警报有效性评估算法的输入为设备属性信息

$$devattrinfo = (\{alert_e\}, config_e, vulnerabilities_e, perinfo_e)$$

以及警报集合

$$\{alert_e\} = \{a_1, a_2, \dots, a_i, \dots, a_M\},$$

输出为有效警报集合

$$\{alert'_e\} = \{a'_1, a'_2, \dots, a'_i, \dots, a'_m\}, \quad m \leq M$$

及其有效性评估值 $p_{threat}(a'_i)$ 。

算法的核心思想是：从设备配置、设备脆弱性与设备性能三个方面抽取属性信息，并分别计算警报在三类信息上的匹配程度，再将它们综合得到警报有效性评估值。原文算法可概括为：

1. 从 $config_e$ 中提取设备配置属性；
2. 从 $vulnerabilities_e$ 中提取设备脆弱性属性；
3. 从 $perinfo_e$ 中提取设备性能属性；
4. 将三类属性总量记为 k ；
5. 对每个警报分别计算其与配置、脆弱性和性能信息的关联程度，得到 $p_{config}(a'_i)$ 、 $p_{vul}(a'_i)$ 、 $p_{per}(a'_i)$ ；
6. 综合三部分结果得到

$$p_{threat}(a'_i) = p_{config}(a'_i) + p_{vul}(a'_i) + p_{per}(a'_i).$$

4.2 基于有效威胁警报的设备状态评估算法

设备威胁状态评估算法以有效警报集合 $\{alert'_e\}$ 及其有效性评估值 $p_{threat}(a'_j)$ 为输入，输出设备当前状态 X_j 及设备处于该状态的概率 $status_probability = p_{threat}(X_j)$ 。

该算法的基本思想是将有效警报进行聚合，以聚合结果表示设备状态，并依据攻击模式确定状态间的父子关系和演化关系。原文给出的状态概率计算式可整理为

$$p_{threat}(X_j) = \frac{1}{q+1} \sum_{i=0}^q p_{threat}(a'_{j+i}),$$

即利用聚合到同一状态中的多个有效警报的平均有效性来刻画设备处于该状态的概率。

4.3 性能劣化对设备威胁态势的影响

设备性能的非正常劣化表征了设备受到拒绝服务的严重程度。设备性能中，CPU 利用率 cp 和内存利用率 mp 的劣化程度表征计算消耗型拒绝服务攻击的强度；带宽利用率 bp 、会话连接 ses_p 、丢包率 $loss_p$ 的劣化程度表征带宽消耗型拒绝服务的强度；设备内部温度则综合反映运行环境对设备计算及带宽性能的影响。

利用性能劣化累积量 $\sum \Delta per_e(i)$ (当设备性能劣化时其值小于 0) 综合表示单位时间内拒绝服务攻击强度, π 表示性能劣化对设备态势的影响程度, 因此设备威胁态势中的性能分量可用

$$\pi \times (-1) \times \sum \Delta per_e(i)$$

表示。

4.4 有效威胁对设备造成的损失

威胁利用设备脆弱性将给设备带来损失, 损失与设备安全属性价值和脆弱性严重程度相关。有效威胁对设备造成的损失定义为

$$status_loss = attrivalue_e \cdot severity. \quad (1)$$

其中, 设备脆弱性的严重程度 $severity$ 包括异常严重程度 $severity_{abn}$ 和漏洞严重程度 $cvss_b$:

$$severity = \frac{1}{20}(severity_{abn} + cvss_b), \quad 0 \leq severity \leq 1. \quad (2)$$

参考 CVSS 对漏洞的评分, 设备异常严重程度为

$$severity_{abn} = 10(1 - (1 - A)(1 - I)(1 - C)). \quad (3)$$

表 2 为原文给出的设备异常分类。

表 2: 设备异常分类

可用性异常 $A(0.3)$	完整性异常 $I(0.3)$	保密性异常 $C(0.4)$
计算性能劣化	启动关键库异常	IPsec 报文异常
带宽性能劣化	硬件检测失败	非策略访问
环境性能劣化	完整性校验失败	加解密错误
服务业务失败	查询状态失败	更换数据失败
管理业务失败	格式解析失败	密钥及算法过期

4.5 设备威胁态势量化评估

通过评估指标、威胁警报有效性评估算法和设备状态评估算法, 可以量化计算设备的威胁态势。原文给出的 ETSA 计算式体现了两种情况:

1. 当设备存在性能劣化, 即 $\sum \Delta per_e(i) < 0$ 时, 威胁态势由状态概率、损失以及性能分量共同构成;
2. 当设备不存在性能劣化, 即 $\sum \Delta per_e(i) \geq 0$ 时, 威胁态势主要由状态概率和损失共同决定。

据此，设备威胁态势量化评估同时综合了有效威胁强度、设备脆弱性造成的损失以及拒绝服务对设备性能的影响。

5 实验分析

为了阐明高安全价值设备威胁评估的原理和过程，验证本文方法的合理性及有效性，本文构建实验网络，在网络环境中评估设备的安全属性价值，确定高安全属性价值设备，并对其进行威胁态势量化评估。

实验网络中，Web 服务（Tomcat）、数据库服务（MongoDB）、负载均衡服务（LVS）及版本管理服务（SVN）通过交换机置于网络 DMZ 域；桌面云服务（Fusion Access）及文件存储服务（NFS）通过 Vlan 置于 Trust 域；系统性能、日志服务（LogServer）及安全文件传输服务（SFTP）置于 Management 域；具有 IPsec 功能的防火墙位于 Trust 域和 Untrust 域的边界。外部连接通过 Untrust 域到 Trust、DMZ 域间的映射实现，整体网络在 DMZ 和 Trust 域部署 Snort（IDS）。防火墙警报及 Snort 警报通过设备信息中心接入 Management 域的 LogServer 及 SFTP。

根据定义 3，当设备安全属性价值 $attrivalue_e \geq \varepsilon$ 且 $4 \leq \varepsilon \leq 5$ 时，设备为高安全属性价值设备。实验网络主要资产信息表明，de_011 和 de_006 为实验网络中的高安全属性价值设备。

表 3: 主要资产信息（简化整理）

设备编号	名称	类型	$(conf, int, avail)$	$attrivalue_e$	主要服务
de_001	Snort	network	(3,3,3)	2.197	snort
de_002	LVS	service	(2,3,4)	2.393	lvs, keepalived
de_003	Tomcat	service	(3,3,4)	2.654	tomcat
de_004	MongoDB	service	(4,3,4)	3.066	mongod
de_005	FA/DNS/AD/DHCP	service	(2,3,4)	2.393	dns, ldap, dhcp
de_006	NFS	service	(5,4,5)	4.066	rpcbind, nfs
de_007	LogServer	service	(4,3,3)	2.737	syslog
de_008	SFtpServer	service	(4,3,3)	2.737	sftp
de_009	SVN	service	(4,4,4)	3.197	svn
de_010	Switcher	network	(2,3,5)	3.115	dhcp
de_011	FW IPsec	security network	(5,5,5)	4.197	http, https, ftp

表 4: 设备脆弱性

设备编号	名称	类型	脆弱性
de_006	NFS	service	CVE-2017-7645, CVE-2017-7187, CVE-2017-7494
de_011	FW	Security	见表 2 中异常项

5.1 实验场景

场景 1：互联网流量场景。开放 de_011 设备 Untrust 域公网接口并开放 DMZ 域 Web 服务；在 de_011 设备上做 NAT，将公网 IP 及端口映射至 Web 服务的负载均衡服务。此时 de_011 设备直接暴露给 Internet 用户，并接收 Internet 访问流量。测试时间为 16:00 至 19:00。该场景的主要特点是设备暴露到 Internet 后，会受到来自不同国家恶意主机对设备类型、端口、服务、存活性等方面的扫描、提权等攻击。数据由 LogServer 及 SFTP 中的警报数据和设备性能命令会话记录的性能数据构成。

场景 2：Internet 侧模拟攻击场景。在场景 1 的基础上，对 de_011 设备进行模拟攻击，de_011 同时接收 Internet 访问流量和测试员 DOS 攻击流量。测试时间为 19:00 至 21:30。具体使用 Nmap、Netwox、Kali 对 de_011 进行端口与服务扫描，并实施 Large ICMP、Syn flood 和 Udp flood 攻击。数据同样来自 LogServer、SFTP 和设备命令性能会话。

场景 3：内网侧模拟攻击场景。模拟内部用户非授权访问 de_006 文件系统的恶意行为。该场景使用 Nmap 对 de_006 设备的端口及服务开放情况进行扫描，之后尝试通过 NFS 通用漏洞提权进入系统；由于系统已安装相应补丁，提权失败后继续发动 Syn flood 和 Udp flood 攻击。测试时间为 21:30 至次日 0:30。警报数据通过 Snort 获取，性能数据通过 Nmon 和 Smokeping 采集 Linux 性能数据。

5.2 结果分析

实验获得数据后，首先对场景 1 至场景 3 的警报数据和性能数据进行对应时间窗口关联，满足警报时间与性能时间的一致性关系；再利用 Java 程序和 MongoDB 对警报和性能数据进行入库预处理，满足评估算法要求；最后使用本文方法对 3 个场景的数据进行分析。

警报有效性评估结果表明，本文方法能够以设备的性能、配置和脆弱性为基础，验证威胁警报、计算警报有效性评估值，并通过评估结果反映威胁对设备作用的有效程度，具体体现在两个方面。

第一，算法 1 能够在大量警报数据中根据设备属性信息提取出有效警报，从警报数量和警报频率层面评估威胁对设备的作用。警报约减率如表 5 所示，平均约减率为 33.04%。以场景 1 为例，在 16:00–19:00 时间段内设备受到有效可见攻击 26 次。

第二，算法 1 能够通过警报评估分值反映威胁对设备作用的有效程度。场景 1 中 de_011 设备在第 25、28、33、38 个警报的评估分值较高，达到 0.67，主要原因是设备在这些时刻受到不同恶意主机连续发起的远程 Telnet 提权攻击，使网络会话连接数、丢包率等性能指标劣化。场景 2 中 de_011 设备在第 63–66 个警报时刻和第 114–119 个警报时刻评估值较高，分别达到 0.67 和 0.44，主要原因是设备分别受到 Syn flood 和 Udp flood 攻击。场景 3 中 de_006 设备在第 155–163 个警报时刻和第 250–257 个警报时刻评估值较高，达到 0.625，反映出拒绝服务攻击对设备作用的程度。

进一步分析表明，设备性能变化与警报评估分值变化具有一致性。场景 1 中评估分值较高的第 25、28、33、38 个警报对应性能第 6 个采样周期；场景 2 中评估分值较高的第 63–66 个警报和第 114–119 个警报分别对应性能第 8 个和第 12 个采样周期；场景

表 5: 警报约减率

条目	警报总次数	有效警报次数	警报约减率
场景 1	147	26	17.69%
场景 2	186	62	33.33%
场景 3	472	178	37.71%

3 中评估分值较高的第 155–163 个警报和第 250–257 个警报分别对应性能第 18 个和第 32 个采样周期。在有效警报对应的性能周期中均出现性能劣化,说明设备性能变化和警报评估分值变化具有一致性。

设备状态评估结果表明,本文方法能够基于警报有效性评估设备所处安全状态。原文根据不同攻击类型发生期间的威胁警报有效性评估值均值区间界定阈值范围,将设备状态划分为正常、扫描、威胁、威胁并拒服以及达成目标等状态,如表 6 所示。场景 1 至场景 3 的状态变化与设备性能变化及警报有效性评估图变化相对应,能够表现设备受到威胁后所处的安全状态。

表 6: 设备威胁状态评估值

状态	界定区间	状态特征	状态值
X_0	$p_{threat}(X_j) < 0.29$	正常	1
X_1	$0.29 \leq p_{threat}(X_j) < 0.33$	扫描	2
X_2	$0.33 \leq p_{threat}(X_j) < 0.67$	威胁	3
X_3	$0.65 \leq p_{threat}(X_j) < 1$	威胁 & 拒服	4
X_4	$0.65 \leq p_{threat}(X_j) < 1$	达成目标	5

原文进一步指出,利用本文提出的设备威胁态势量化评估指标和评估方法,计算得到的设备威胁态势与设备安全状态相对应,评估结果与实验场景的实际测试一致,能够准确、有效地量化评估设备威胁态势。例如,在 19:42、20:02、21:02、21:22、22:22 和 22:52 均发生拒绝服务攻击,对应时刻设备具有较高的威胁量化评估值和较高等级的安全状态,且二者变化趋势与实验场景中的模拟攻击行为一致。

5.3 对比分析

在介绍本文方法的基础上,原文综合其他评估方法,从不同角度与本文方法进行对比分析。比较指标包括评估对象、属性、方法类型、结果形式、普适程度、知识来源、警报约减和警报聚合等。对比结果如表 7 所示。

对比分析可概括为以下三点:

1. 针对网络的评估方法在网络威胁态势量化评估方面体现出评估结果的宏观性、整体性及趋势性;针对设备的评估方法则能够立足具体设备对确定对象进行评估,在微观层面针对性更强,是对网络威胁态势评估的有效补充。
2. 在针对设备的威胁评估方法中,本文方法抽象出了设备安全属性相关的评估指标,

表 7: 威胁态势评估方法比较

评估方法	评估对象	属性	方法类型	结果形式	普适程度	知识来源	警报约减	警报聚合
文献 [19]	网络	宏观	分类法	分数	中	概率方式	不支持	支持
文献 [17]	网络	宏观	马尔可夫	分数	中	推理方式、概率方式	不支持	不支持
文献 [27]	网络	宏观	权重法	分数	高	领域专家	支持	不支持
文献 [18]	网络	宏观	权重法	分数	中	领域专家	支持	不支持
文献 [20]	设备	微观	公式法	分数	低	推理方式	不支持	不支持
文献 [24]	基础设施	宏观	贝叶斯	分数	中	概率方式	不支持	不支持
本文方法	设备	微观	公式法	分数	高	概率方式	支持	支持

- 相比使用路由器位置和交换容量来衡量设备对安全风险影响程度的方法，具有更好的通用性。
3. 在知识来源方面，本文方法较少依赖领域专家和经验，评估方式基于概率方式；相比通过专家经验赋值环境属性相关度和威胁发生可能性的方式，在评估方法的客观性方面更具优势。

6 结束语

本文在给出高安全属性价值设备定义的基础上，提出了针对设备的威胁态势量化评估框架和评估指标，并根据该框架和指标提出了高安全属性价值设备威胁态势量化评估方法。该方法以设备的性能、配置和脆弱性为基础，验证威胁警报并评估威胁警报的有效性；基于有效警报构建设备状态评估算法，评估设备所处安全状态；进一步利用评估指标量化计算设备威胁态势。

实验结果表明，本文方法的评估过程与评估结果与网络规模变化不直接构成函数关系，网络规模变化不影响方法的计算复杂度，体现出较强的网络规模适用性。对具体网络中实际设备的评估结果表明，该方法能够准确、有效地量化评估高安全属性价值设备的威胁态势。通过方案对比分析可知，本文方法在应用通用性及评估结果客观性方面具有优势。

参考文献

1. 龚正虎, 卓莹. 网络态势感知研究 [J]. 软件学报, 2010, 21(7): 1605-1619.

2. CYRIL O. Understanding cyber situation awareness[J]. International Journal on Cyber Situational Awareness, 2016, 1(1): 11-30.

3. BLASCH E, PLANO S. JDL level 5 issues supporting situational assessment reasoning[C]//Proc of the Signal Processing, Sensor Fusion, and Target Recognition XI (SPIE). 2002: 270-279.
4. ENDSLEY M. Situation awareness global assessment technique (SAGAT)[C]//Proc of the IEEE'88 National Aerospace and Electronics Conf. 1988: 789-795.
5. AGGARWAL P, GONZALEZ C, DUTT V. Cyber-security: role of seception in cyber-attack detection[C]//International Conference on Applied Human Factors and Ergonomics. 2016: 85-96.
6. SUN X, DAI J, LIU P, et al. Towards probabilistic identification of zero-day attack paths[J]. Communications and Network Security, 2017: 64-72.
7. ZHANG H, YAO D, RAMAKRISHNAN N, et al. Causality reasoning about network events for detecting stealthy malware activities[J]. Computers & Security, 2016, 58(C): 180-198.
8. SHAO P, LU J, WONG R K, et al. A transparent learning approach for attack prediction based on user behavior analysis[C]//International Conference on Information and Communications Security. 2016: 159-172.
9. 刘效武, 王慧强, 吕宏武, 等. 网络安全态势认知融合感控模型 [J]. 软件学报, 2016, 27(8): 2099-2114.
10. 文志诚, 陈志刚, 唐军. 基于信息融合的网络安全态势量化评估方法 [J]. 北京航空航天大学学报, 2016, 42(8): 1593-1602.
11. 赵淦森, 吴杰超, 陈梓豪, 等. 网络空间安全态势感知研究 [J]. 网络与信息安全学报, 2016, 2(10): 29-35.
12. 朱承, 缪嘉嘉, 毛捍东. 面向行为的内网空间安全态势建模与分析 [J]. 网络与信息安全学报, 2016, 2(8): 17-22.
13. ELIAS B H, MARTIN H, MOURAD D, et al. Big data sanitization and cyber situational awareness: a network telescope perspective[J]. IEEE Transactions on Big Data, 2017, 99: 1-8.
14. MIN D, LEI F F, ZHENG G N, et al. DeepLog: anomaly detection and diagnosis from system logs through deep learning[C]//ACM Sigsac Conference (CCS'17). 2017: 1285-1298.
15. 寇广, 王硕, 张达. 基于深度堆栈编码器和反向传播算法的网络安全态势要素识别 [J]. 电子与信息学报, 2019, 41(9): 2187-2193.
16. 程家根, 祁正华, 陈天赋. 基于 RBF 神经网络的网络安全态势感知 [J]. 南京邮电大学学报 (自然科学版), 2019, 39(4): 88-95.

17. 张勇, 谭小彬, 崔孝林, 等. 基于 Markov 博弈模型的网络安全态势感知方法 [J]. 软件学报, 2011, 22(3): 495-508.
18. 席荣荣, 云晓春, 张永铮. 一种改进的网络安全态势量化评估方法 [J]. 计算机学报, 2015, 38(4): 749-758.
19. 杨豪璞, 邱辉, 王坤. 面向多步攻击的网络安全态势评估方法 [J]. 通信学报, 2017, 38(1): 187-198.
20. 杨君刚, 梁礼, 刘故箐, 等. 在线监测的路由器安全威胁态势量化评估方法 [J]. 通信学报, 2013, 34(11): 59-70.
21. YU B L, ALI A K, SELVAKUMAR M, et al. An adaptive assessment and prediction mechanism in network security situation awareness[J]. Journal of Computer Sciences, 2017, 13(5): 114-129.
22. CRISTINA A J. Wide-area situational awareness for critical infrastructure protection[J]. IEEE Computer, 2013, 46(4): 30-37.
23. CRISTINA A, SHERALI Z. Critical infrastructure protection: requirements and challenges for the 21st century[J]. International Journal of Critical Infrastructure Protection, 2015, 8: 53-56.
24. CEEMAN V, ANURAG S, SAMAN Z. CPIndex: cyber-physical vulnerability assessment for power-grid infrastructures[J]. IEEE Transactions on Smart Grid, 2017, 6(2): 566-575.
25. 国家信息中心. GB/T 20984-2007 信息安全技术信息安全风险评估规范 [S]. 北京: 中国标准出版社, 2007.
26. CVSS-Common Vulnerability Scoring System[EB].
27. 韦勇, 连一峰. 基于日志审计与性能修正算法的网络安全态势评估模型 [J]. 计算机学报, 2009, 32(4): 763-772.
28. Snort-the open source network intrusion detection system[EB].
29. Nmap-free security scanner for network[EB].
30. Netwox-a toolbox for network[EB].
31. Kali linux-a Debian-derived linux distribution designed for digital forensics and penetration testing[EB].
32. Nmon-the linux system performance tools[EB].
33. Smokeping-a toolbox for tracking of your network latency[EB].